PER2025-053

Exploitation d'un **driver vulnérable** sur Windows dans le cadre du **hacking éthique**

Encadrants: Yves **ROUDIER** (yves.roudier@univ-cotedazur.fr), Florian **ECARD** (fecard@hackmosphere.fr)
Étudiants: CyberSec, mail: [prenom].[nom]@etu.univ-cotedazur.fr
Romain **CHARDINY**, Mathias **SANTOS REIS**, Yohan **MAZZI**, Ilias **MOUTAOUKIL**

Un **driver** (ou pilote) est un **logiciel système** qui permet au système d'exploitation de **communiquer avec les composants matériels** (carte son, réseau, clavier, etc.).

Parce qu'ils fonctionnent avec des **droits très élevés**, les drivers représentent une **cible sensible en matière de sécurité**.

Une attaque de type **BYOVD** (Bring Your Own Vulnerable Driver) consiste à utiliser un driver légitime mais vulnérable afin de **contourner les protections du système** et **obtenir des privilèges élevés**.

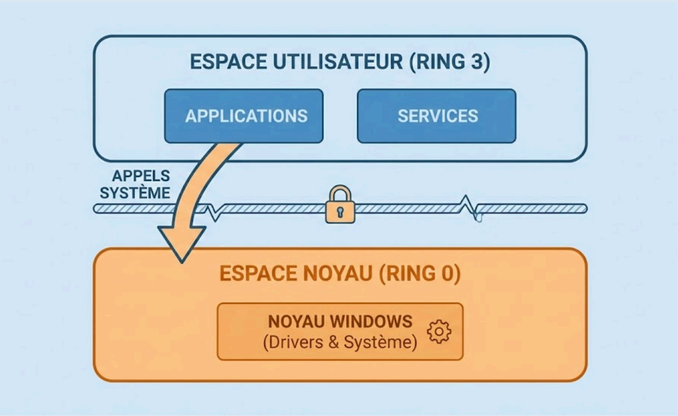
Environnement

- **Machine virtuelle** : Windows 11 25H2 (Build 26200.7623)
  - Environnement isolé pour les tests, permettant de travailler en sécurité et de restaurer facilement un état précédent (snapshots)
- **Machine hôte** : WinDbg (debug kernel)
  - Analyse et débogage du driver et du noyau depuis l'extérieur de la machine virtuelle.

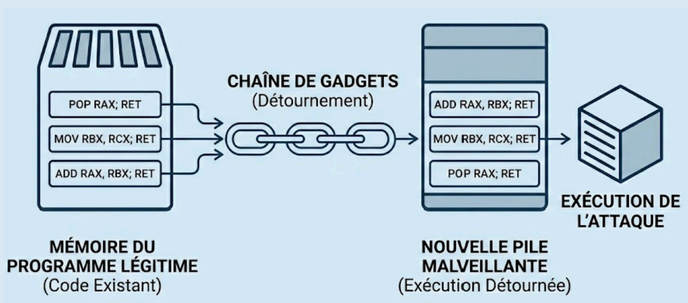
Objectifs

- Montrer comment un **driver légitime mais vulnérable** peut permettre d'obtenir un **accès en mode noyau**.
- En exploitant ses failles, **contourner les mécanismes de protection** de Windows afin d'**exécuter du code avec les privilèges les plus élevés**.
- L'objectif final est d'**élever les privilèges** du processus attaquant jusqu'au niveau **NT AUTHORITY\SYSTEM**.

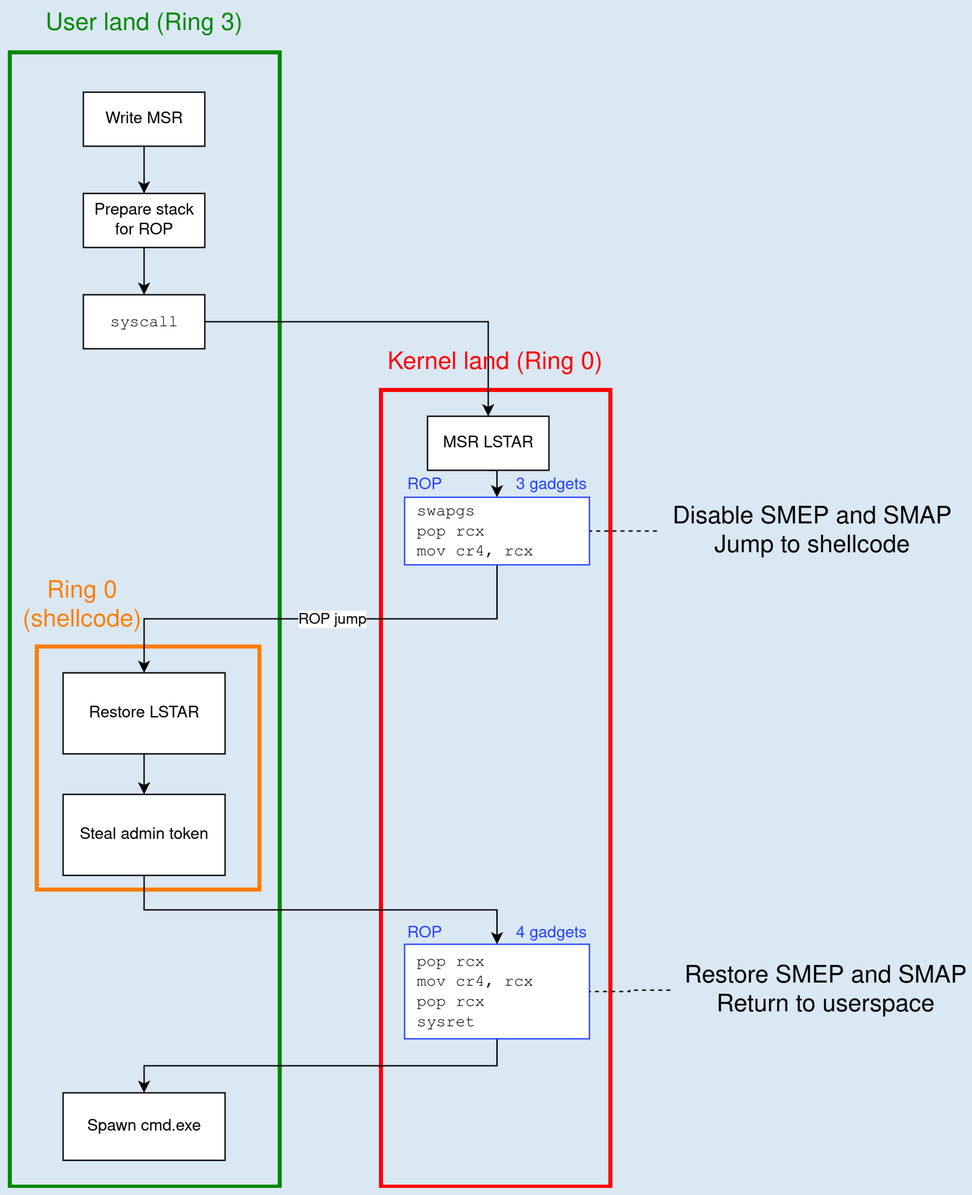
- **Séparation des différents espaces sur windows** :
  - espace utilisateur - Ring 3
  - espace Noyau - Ring 0



- Un **ROP Gadget** est un minuscule fragment de code légitime déjà présent dans la mémoire d'un programme. Les attaquants enchaîne ces fragments les uns à la suite des autres pour construire et exécuter une attaque complexe sans avoir à injecter leur propre code.



- **Vulnérabilité LnvMSRIO.sys (Driver présent sur les ordinateurs Lenovo)**
  - **CVE-2025-8061** touche le pilote noyau Lenovo Dispatcher (v3.0–3.1) distribué par Lenovo. Le pilote expose des **IOCTL insuffisamment contrôlés** permettant à un utilisateur local authentifié d'effectuer des opérations privilégiées depuis l'espace utilisateur.
  - Le défaut permet notamment **l'accès à des instructions sensibles** (lecture/écriture de Model Specific Registers). L'exploitation consiste à modifier le **MSR LSTAR**, registre qui contient l'adresse du point d'entrée noyau appelé par l'instruction SYSCALL sur x86-64. En remplaçant cette adresse par un pointeur contrôlé, l'attaquant détourne le flux d'exécution lors du prochain appel système.
  - L'exploitation peut être réalisée via une chaîne **ROP** : l'attaquant prépare des gadgets en mémoire noyau afin de **contourner les protections** (SMEP/SMAP) et d'obtenir une exécution fiable en ring 0.



Diffiultés d'une exploitation système

L'exploitation dépend :

- du **Windows** (numéro, version, build)
- des **sécurités actives**

Résultat : **changements d'adresses** utilisées lors de l'exploitation et **différentes sécurités** à contourner.
→ Il faut **adapter l'attaque** à chaque système cible.

HEVD (driver volontairement vulnérable) nous a également montré qu'une **différence du CPU** peut entraîner des changements :

Configuration sécurité: **KVA Shadow**
Intel (config A) — **AMD** (config B)

Bilan des résultats

- **Succès technique** : Obtention d'un shell avec privilèges *NT AUTHORITY\SYSTEM*
- **Stabilité** : Réussite de la restauration de l'état du système après exploit (pas de crash système

Prise de recul

- **Complexité du developpement kernel** : La moindre erreur entraîne un crash complet (BSOD)
- **Efficacité du BYOVD** : Démonstration que même un système à jour peut être compromis si un driver tiers vulnérable est autorisé

Perspectives / amélioration

- Essayer l'exploit avec le maximum de sécurité déployé.
- **Détecteur de vulnérabilité** : Essayer de créer un détecteur de cette faille précisément afin d'industrialiser l'exploit.

POLYTECH NICE SOPHIA

UNIVERSITÉ CÔTE D'AZUR